L'analyse des en-tête HTTP et la recherche DNS inversée peuvent être efficaces, mais de nombreux outils automatisent et rendent plus efficace ce processus. Notons d'abord que la recherche de vhost génère du trafic important et peux nous faire bloquer par les IDS et pare-feu d'applications web (WAF)

Principaux outils : gobuster, feroxbuster, ffuf

Quelque commande (enum vhost avec gobuster) :

```
Agentpathogène@parrot~$ gobuster vhost -u http://target_ip_adresse -w /path/to/wordlist/file --append-domain
```

Le flag --append-domain ajoute le domaine de base à chaque mot de la wordlist, ce flag n'avais pas besoin d'être préciser dans les anciennes versions de gobuster

Notons aussi les flags -t pour augmenter le nombre de thread permettant une analyse plus rapide -k pour ignorer les erreurs de certificats SSL/TLS. -o pour enregistrer la sortie dans un fichier.

Quand à ffuf il faut ajouter le header Host et ajouter le mot clé FUZZ à l'endroit du vhost et ensuite faire un -fs taille de la réponse par défault.

Journaux de Transparence des Certificats :

• Dans l'immensité tentaculaire d'Internet la confiance est une denrée fragile. L'un des piliers de cette confiance est le protocole (SSL/TLS) qui chiffre la communication entre votre navigateur et un site web. Au cœur de ce protocole se trouve le certificat numérique, un petit fichier qui vérifie l'identité d'un site web et permet une communication sécurisée et chiffrée.



• Mais le processus de gestion et d'émission des certificats n'est pas infaillible les attaquant peuvent exploiter des certificats frauduleux remis à tord pour usurper l'identité de sites web légitimes. C'est là que les journaux de transparence de certificat entrent en jeu.

• Les journaux de transparence des certificats (CT) sont des registres publics en ajout seul qui enregistrent l'émission des certificats SSL/TLS, quand une autorité de certification (AC) émet un nouveau certificat elle doit le soumettre à plusieurs CT et tout le monde peux les consulter. Cela permet la revocation des certificats frauduleux, la responsabilisation des autorités de certification

Plusieurs site web permettent d'interroger les CT notons : crt.sh

Fingerprinting (Prise d'empreinte) :

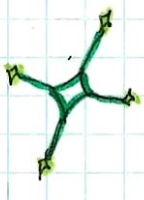
Le finger printing se concentre sur l'extraction de détailles (critiques) techniques sur les technologies qui alimentent la cible. Cette connaissance est essentielle à l'attaquant, chaque cible a sa signature numérique particulière, comme les empreintes de pouce, Cela permet :

[1] Attaques ciblés
[2] Identifications des mauvaises configurations
[3] Priorisation des cibles
[4] Construction d'un profil complet.

Pour certaines techniques notons : Banner Grabbing : Analyse des entêtes HTTP : Sondage pour des reponses spécifiques Analyse du contenu de la page.

Notons quelques outils intéressants : Wappanalyzer, WhatWeb, Nmap, et pour identifier les pare-feu web wafw00f

Crawling :



Le crawling souvent appelé spidering est le processus automatisé de parcours systématique du World Wide Web ; comme une araignée se déplace sur sa toile un robot d'exploration suis les liens d'une page à l'autre collectant des informations ces robots permettent l'indexation de pages web les rendant accessibles aux moteurs de recherches, ou bien l'analyse de donnée ou encore reconnaissance web. Le contexte est important dans l'analyse de données obtenues ainsi, mais cette technique si on code bien